Comprehensive Security Operations Project Review

By

Oluwatobi Babalola

Classification: CONFIDENTIAL

INCIDENTS	USERS AFFECTED	DATA EXFILTRATED	SENTINEL RULES	PLAYBOOKS
3	7	2 FILES	8	3

Executive Summary

Between 25 July 2023 and 11 March 2024, this organization faced a series of targeted cyber incidents that, upon thorough investigation, revealed the characteristics of a coordinated, intelligence-driven attack campaign. The Security Operations team detected and addressed a synchronized phishing campaign aimed at several staff members, a confirmed account breach that led to the theft of sensitive financial and security information, and an attempt to deliver ransomware to a VIP user at a partner financial institution.

The phishing campaign, which affected five staff members from various departments on 29 July 2023, was succeeded within 24 hours by the compromise of a Financial Analyst's account. The attacker gained access to and downloaded two extremely sensitive documents: the organization's payroll data and its internal vulnerability assessment report. Eight months later, a WannaCry ransomware payload was sent to a VIP user utilizing the same Office document phishing method used by Storm-0978, a Russian-affiliated threat actor recognized for targeting the finance and government sectors.

The Security Operations team thoroughly investigated all incidents, contained ongoing threats, extracted indicators of compromise, created detection rules in Microsoft Sentinel, and formulated incident response playbooks to avert future occurrences. Simultaneously, vulnerability management assessments uncovered critical unpatched vulnerabilities in Microsoft products and Android mobile devices that required immediate attention.

CRITICAL FINDING — COORDINATED CAMPAIGN

Evidence across Tasks 1, 2, and 3 indicates a single coordinated attack campaign rather than three isolated incidents. The phishing campaign (29 July) preceded the account compromise (30 July) by one day. The exfiltrated vulnerability report gave the attacker knowledge of unpatched systems. The subsequent ransomware delivery (11 March 2024) used the exact Office document phishing vector documented as exploitable in that report.

1. Incident Overview

Ref	Incident	Date	Severity	Summary
INC-01	Phishing Campaign	29 July 2023	CRITICAL	Coordinated phishing campaign targeting 5 staff across departments. 4 of 5 emails confirmed malicious. NjRAT delivery, Google Drive malware, Adobe brand impersonation, browser attack toolkit.
INC-02	Account Compromise	30–31 July 2023	CRITICAL	Financial Analyst credentials compromised. Successful logins from Bulgarian VPS and Chinese Tencent Cloud infrastructure. Payroll data and vulnerability report exfiltrated.
INC-03	Ransomware Delivery	11 March 2024	CRITICAL	WannaCry ransomware delivered to VIP user at partner institution via RAR attachment containing diskpart.exe. ESA AV verdict negative; CrowdStrike blocked it.

2. Unified Incident Timeline

The following timeline covers all security incidents identified during the sprint reporting period. Vulnerability management events are excluded per reporting guidelines.

Date / Time	Incident	Event
25 Jul 2023 09:00–17:10	INC-02	Erwin Smith conducts normal working activity from IP 143.58.226.102 (Manchester, UK, Hyperoptic). Baseline established. caffeine.exe mouse jiggler executed at 17:10 - policy violation noted.
25 Jul 2023 17:10	INC-02	Mouse jiggler software (caffeine.exe) executed on Erwin Smith device. SHA256: 288b534... Not malware but policy violation - prevents idle screen lock.
26–28 Jul 2023	INC-02	Continued normal activity from UK IP. Pattern establishes clear baseline for anomaly detection.
29 Jul 2023 14:22–15:28	INC-01	Coordinated phishing campaign: 5 staff targeted within 90 minutes. Emails included NjRAT, Google Drive malware, Adobe impersonation, and display name spoofing.
30 Jul 2023 10:45	INC-02	First suspicious login attempt on Erwin Smith account from 79.124.60.6 (Sofia, Bulgaria - VenomDC bulletproof hosting). Microsoft Exchange login failed.
31 Jul 2023 09:50	INC-02	Successful login from 150.158.77.170 (Shanghai, China - Tencent Cloud). Microsoft Online success. IP confirmed malicious: 3/94 VT, HTTP bruteforce history.
31 Jul 2023 10:20	INC-02	Attacker accesses vulnerability_report_June2023.docx via SharePoint. File contains known unpatched vulnerabilities - critical intelligence for follow-on attacks.
31 Jul 2023 17:10	INC-02	Attacker downloads updated_payroll.xlsx from SharePoint. Payroll data for all staff exfiltrated.

11 Mar 2024 09:14	INC-03	CrowdStrike CSP alert triggered on Cisco ESA. Email to VIP from UUID sender at azxmarket.com. Attachment Catalogue.rar containing diskpart.exe - WannaCry binary.
11 Mar 2024 09:16	INC-03	Investigation initiated. File hash confirmed as WannaCry: 68/72 VT detections, Joe's Sandbox 100/100. Full attack chain documented.

3. MITRE ATT&CK Campaign Mapping

The following table maps the full campaign across all three incidents to the MITRE ATT&CK Enterprise framework.

Tactic	Technique	Sub-Technique	Observed Activity
Reconnaissance	T1589	Gather Victim Identity Information	Attacker demonstrated prior knowledge of staff roles and names.
Initial Access	T1566	Phishing	Five phishing emails delivered to staff on 29 July 2023. Four confirmed malicious.
Initial Access	T1566.001	Spearphishing Attachment	WannaCry delivered via RAR archive containing diskpart.exe.
Initial Access	T1078	Valid Accounts	Compromised credentials of Erwin Smith used to authenticate to Microsoft 365.
Execution	T1204.002	Malicious File	WannaCry binary executed when extracted from Catalogue.rar.
Execution	T1059.005	Visual Basic	WannaCry executes m.vbs via cscript.exe.
Persistence	T1547.001	Registry Run Keys / Startup Folder	WannaCry writes HKLM\SOFTWARE\WannaCrypt and startup folder artifacts.
Defense Evasion	T1036	Masquerading	WannaCry binary named diskpart.exe to impersonate a legitimate Windows tool.
Credential Access	T1110	Brute Force	Multiple failed login attempts before successful authentication.
Discovery	T1046	Network Service Discovery	WannaCry scans subnet for port 445 (SMB).
Lateral Movement	T1021.002	SMB/Windows Admin Shares	Exploitation of MS17-010 / EternalBlue via SMB port 445.

Collection	T1213	Data from Information Repositories	Attackers accessed and downloaded sensitive documents from SharePoint.
Command & Control	T1090	Proxy	WannaCry communicates via Tor using embedded .onion C2 addresses.
Exfiltration	T1048	Exfiltration Over Alternative Protocol	Payroll and vulnerability data exfiltrated via authenticated SharePoint session.
Impact	T1486	Data Encrypted for Impact	WannaCry encrypts victim files with the .WNCRY extension.
Impact	T1490	Inhibit System Recovery	WannaCry deletes Volume Shadow Copies to prevent recovery.

3.2 MITRE ATT&CK Hypothesis — Unconfirmed Techniques

HYPOTHESIS — Insufficient Evidence for Definitive Attribution

Techniques such as T1591, T1598, and T1657 are hypothesised based on circumstantial evidence but cannot be confirmed from available log data.

4. Threat Actor Assessment

4.1 Storm-0978 / RomCom — Primary Attribution Hypothesis

The approach, focus, and timing of INC-03 align with Storm-0978, which is also known as RomCom, DEV-0978, Tropical Scorpius, and UNC2596. Storm-0978 is a threat actor linked to Russia, operating with a dual purpose: conducting financially driven ransomware attacks and intelligence-gathering efforts aimed at the defense, government, finance, and telecommunications sectors in both Europe and North America.

In July 2023, Microsoft verified that Storm-0978 was actively taking advantage of CVE-2023-36884 to deploy ransomware through phishing emails that included harmful Office documents. The attack method utilized in INC-03 mirrors this strategy.

Attribute	Assessment
Attribution Confidence	MEDIUM - Technique and targeting consistent with Storm-0978. Definitive attribution requires additional forensic evidence.
Threat Actor	Storm-0978 / RomCom (hypothesis). Alternative: independent financially motivated actor using publicly available WannaCry sample.
Motivation	Dual - financial and intelligence gathering.
Targeting Profile	Finance sector, VIP users, organisations with Microsoft 365 infrastructure.
Was Risk Pre-Identified?	Partially. The June 2023 vulnerability report documented unpatched vulnerabilities.

4.2 Secondary Threat Actor — INC-01 Phishing Campaign

The phishing operation in INC-01 featured various sender addresses. The deployment of NjRAT targeting a Lead Software Engineer indicates a skilled individual aiming to infiltrate development systems. It remains unclear if this individual is connected to Storm-0978 based on the evidence at hand.

5. Cross-Incident Correlation

KEY FINDING — Single Coordinated Campaign

The incidents are assessed with MEDIUM-HIGH confidence to represent a single coordinated attack campaign rather than independent events. The evidence chain links phishing, account compromise, exfiltration of the vulnerability report, and later ransomware delivery.

5.1 How the Incidents Relate

- INC-01 → INC-02: The phishing campaign preceded the first suspicious login attempt by less than 24 hours. The most probable credential theft vector is an unreported phishing email or credential capture aligned with the same campaign infrastructure.
- INC-02 → INC-03: The vulnerability report exfiltrated on 31 July gave the attacker a roadmap of unpatched systems and viable attack vectors.
- INC-01 + INC-03: Both incidents used email-delivered malicious attachments and social engineering pretexts.
- Staff reconnaissance: Role-specific pretexts indicate prior knowledge of staff roles and responsibilities.

6. Vulnerability Management Summary

6.1 Microsoft Patch Tuesday — July 2023

Microsoft's July 2023 Patch Tuesday addressed 132 vulnerabilities including 37 RCEs and 6 actively exploited zero-days. CVE-2023-36884 had no patch available at time of release and was actively exploited by Storm-0978.

CVE	CVSS	Status	Action Required
CVE-2023-36884	8.3	NO PATCH	Enable ASR rule - Block Office child processes. Ensure M365 Apps 2302+.
CVE-2023-35311	8.8	PATCH AVAILABLE	Deploy KB5028185 immediately - Outlook security bypass.
CVE-2023-32049	8.8	PATCH AVAILABLE	Deploy KB5028185 = SmartScreen bypass.
CVE-2023-32046	7.8	PATCH AVAILABLE	Deploy KB5028185 - MSHTML EoP via email attachment.
CVE-2023-36874	7.8	PATCH AVAILABLE	Deploy KB5028185 - Windows Error Reporting EoP.
CVE-2023-32057	9.8	PATCH AVAILABLE	Audit MSMQ service. Patch or disable.

6.2 Android Device Vulnerability Management

The organisation operates 500 Android devices with no MDM solution. 200 devices are at least one year outdated and 50 devices are at least two years outdated. Three actively exploited CVEs affect the fleet: CVE-2023-2136, CVE-2021-29256, and CVE-2023-26083.

- 250 devices confirmed vulnerable to all three CVEs - immediate update required.
- 50 devices are 2+ years outdated - requiring device replacement not just updates.
- No MDM solution means no central visibility, no policy enforcement, no remote wipe capability.
- Recommended action: Deploy Microsoft Intune, enforce minimum Android version policy, and replace critical-risk devices.

7. Detection & Response Capability Assessment

7.1 What Worked

- CrowdStrike EDR detected the WannaCry payload despite Cisco ESA antivirus returning a negative verdict.
- User reporting was effective across INC-01 - all five affected staff reported suspicious emails.
- Sentinel sign-in logs provided sufficient data to reconstruct the INC-02 attack timeline.

7.2 Detection Gaps Identified

Gap	Impact	Remediation
Cisco ESA missed WannaCry payload	Critical threat reached user inbox undetected	Deploy Microsoft Defender for Office 365 Safe Attachments in Block mode
No Conditional Access policy for foreign IP logins	Attacker authenticated from Bulgaria and China without challenge	Block non-GB logins without MFA from known compliant device
No impossible travel detection active	Attacker logged in from 3 countries in 4 hours undetected	Enable Microsoft Defender for Identity
No sensitivity labels on confidential documents	Payroll and vulnerability report downloaded without alert	Apply Purview sensitivity labels and download alerts
No patch management SLA	Critical CVEs lacked formal remediation timeline	Emergency 48hr, Critical 7 days, High 14 days
No MDM for 500 Android devices	No patch visibility or remote wipe capability	Deploy Microsoft Intune
caffeine.exe on corporate device	Mouse jiggler bypasses idle timeout	Implement application allowlist
No coordinated campaign detection rule	Incidents initially treated as isolated	Sentinel Rule 8 and cross-incident correlation added

8. Controls Recommendations

Category	Priority	Recommendation
Technical	CRITICAL	Deploy Microsoft Defender for Office 365 Safe Attachments in Block mode across all mailboxes.
Technical	CRITICAL	Implement Conditional Access policy blocking logins from outside the UK without phishing-resistant MFA from a known, compliant device.
Technical	CRITICAL	Enable Microsoft Defender for Identity.
Technical	CRITICAL	Patch MS17-010 (EternalBlue) across all Windows systems.
Technical	HIGH	Deploy Microsoft Intune for all 500 Android devices.
Technical	HIGH	Apply Microsoft Purview sensitivity labels to all confidential documents.
Technical	HIGH	Disable SMBv1 across the estate via Group Policy.
Technical	HIGH	Enable Attack Surface Reduction rule: Block Office applications from creating child processes.
Logical	CRITICAL	Block archive attachments containing executables at the email gateway.
Logical	HIGH	Implement network segmentation limiting internal SMB connectivity.
Logical	HIGH	Enforce 3-2-1 immutable backup policy.
Administrative	CRITICAL	Implement formal patch management policy with emergency and critical SLAs.
Administrative	HIGH	Subscribe to CISA KEV catalogue feed.
Administrative	HIGH	Conduct quarterly phishing simulation and awareness training.
Administrative	MEDIUM	Establish a device lifecycle policy.

Administrative	MEDIUM	Implement cross-incident correlation process in the SOC.

9. Lessons Learned

9.1 Incident Response Process

- User reports served as the main detection method for INC-01. Automated detection has now been implemented.
- The investigation of INC-02 faced challenges due to the lack of Conditional Access issues.
- Initially, the three incidents were regarded as distinct occurrences; however, correlation was recognized during the sprint review.
- The response to INC-03 was successful, but the eight-month delay indicates a methodical attacker.

9.2 Process Gaps

- There was no established framework for classifying incident severity.
- The standard investigation process lacked a cross-incident correlation check.
- A formal communication timeline or template was not apparent in the existing process.
- The violation of the caffeine.exe policy should have triggered a compliance review of endpoints sooner.

9.3 Positive Outcomes

- Three high-quality incident response playbooks were developed.
- Eight tailored Sentinel detection rules were formulated based on actual IOCs.
- The identification of the coordinated campaign was the most valuable analytical discovery of the sprint.

10. Recovery Next Steps

10.1 Immediate (This Week)

- Reset Erwin Smith credentials and enforce MFA re-enrollment.
- Notify Data Protection Officer of payroll data exfiltration.
- Deploy KB5028185 across all Windows systems.
- Enable CVE-2023-36884 ASR rule mitigation.
- Block all Task 1, 2, and 3 IOCs at email gateway, firewall, and DNS filter.

10.2 Short Term (This Month)

- Deploy Microsoft Defender for Office 365 Safe Attachments in Block mode.
- Implement Conditional Access policy for UK-only logins.
- Begin MDM procurement and evaluate Intune licensing.
- Conduct Android device inventory.
- Initiate device replacement for 50 Android devices that are 2+ years outdated.
- Tune Sentinel Rule 3 foreign IP sign-in and whitelist legitimate travel exceptions.

10.3 Medium Term (This Quarter)

- Deploy Microsoft Intune across all 500 Android devices.
- Implement Microsoft Purview sensitivity labels on all confidential documents.
- Establish formal patch management SLA policy.
- Conduct phishing simulation exercise.
- Subscribe to CISA KEV catalogue feed.
- Schedule tabletop exercise simulating coordinated phishing plus credential compromise.

Appendix A — Master IOC Reference

The complete master IOC list is maintained in the Task 7 report Section 2 and has been imported into Microsoft Sentinel as watchlist entries. For the most current version of the IOC list, refer to the Sentinel watchlist rather than this document.

Appendix B — Incident Response Playbooks

Three incident response playbooks were developed as part of Task 5: Phishing Email Incident, Account Compromise / Suspicious Sign-In, and Ransomware / Malware Delivery. Each playbook follows the NIST SP 800-61 four-phase framework.

Appendix C — Sentinel Analytics Rules

Eight custom analytics rules were created in Microsoft Sentinel as documented in sentinel_alerts.docx. Rules cover phishing, malicious domain contact, foreign IP sign-in, WannaCry, account compromise, and coordinated phishing campaign detection.

Appendix D — Supporting Reports

Document	Description	Task
phishing_investigation.pdf	Full investigation of 5 phishing emails including IOC analysis, VirusTotal and URLScan evidence, response actions	Task 1
suspicious_signin_investigation.pdf	Full account compromise investigation including IP geolocation, sign-in log analysis, activity log correlation	Task 2
malware_analysis_report.pdf	Complete malware analysis including static analysis, dynamic analysis, process tree, and network behaviour	Task 3
vulnerability_management_report.pdf	Microsoft July 2023 Patch Tuesday assessment and vulnerability management strategy	Task 4
incident_playbooks.pdf	Three NIST SP 800-61 aligned incident response playbooks	Task 5
android_vulnerability_report.pdf	Android CVE risk assessment for 500-device fleet and MDM strategy	Task 6
sentinel_alerts.pdf	Eight custom Microsoft Sentinel analytics rules with KQL queries, IOC master list, MITRE mappings	Task 7